

مؤسسة النقد العربي السعودي

Saudi Arabian Monetary Authority



Cyber Security Framework

Saudi Arabian Monetary Authority

Version 1.0

May 2017

Foreword

In view of the ever-growing seriousness of cyber-attacks, we are conscious of the need to stay one-step ahead. The issuance of a Cyber Security Framework (“Framework”) seeks to support our regulated entities in their efforts to have an appropriate cyber security governance and to build a robust infrastructure along with the necessary detective and preventive controls. The Framework articulates appropriate controls and provide guidance on how to assess maturity level.

The adoption and implementation of the Framework is a vital step for ensuring that Saudi Arabian Banking, Insurance and Financing Companies sectors can manage and withstand cyber security threats. In designing the Framework, we have considered the ways that our regulated entities are leveraging technology and felt that each entity will be able to adopt a common approach for addressing cyber security. This will ensure cyber security risks are properly managed throughout the sectors

To achieve the above, the full support and oversight from the Board of Directors and Senior Management are required for its implementation.

The Information Technology Risk team within the Deputyship of Supervision is at your disposal for any clarifications and we remain committed to guiding our regulated entities in creating a safer cyber environment.

Ahmed Al Sheikh
Deputy Governor for Supervision

Contents

1	Introduction.....	5
1.1	Introduction to the Framework	5
1.2	Definition of Cyber Security	5
1.3	Scope.....	6
1.4	Applicability.....	6
1.5	Responsibilities	7
1.6	Interpretation.....	7
1.7	Target Audience	7
1.8	Review, Updates and Maintenance	7
1.9	Reading Guide	7
2	Framework Structure and Features	8
2.1	Structure	8
2.2	Principle-based.....	9
2.3	Self-Assessment, Review and Audit	9
2.4	Cyber Security Maturity Model.....	10
2.4.1	Maturity Level 3	10
2.4.2	Maturity Level 4	11
2.4.3	Maturity Level 5	12
3	Control domains	13
3.1	Cyber Security Leadership and Governance	13
3.1.1	Cyber Security Governance.....	13
3.1.2	Cyber Security Strategy.....	14
3.1.3	Cyber Security Policy.....	14
3.1.4	Cyber Security Roles and Responsibilities.....	15
3.1.5	Cyber Security in Project Management	17
3.1.6	Cyber Security Awareness.....	17
3.1.7	Cyber Security Training	18
3.2	Cyber Security Risk Management and Compliance	19
3.2.1	Cyber Security Risk Management	19
3.2.2	Regulatory Compliance	22
3.2.3	Compliance with (inter)national industry standards	22
3.2.4	Cyber Security Review.....	22

3.2.5	Cyber Security Audits	23
3.3	Cyber Security Operations and Technology.....	24
3.3.1	Human Resources	24
3.3.2	Physical Security.....	24
3.3.3	Asset Management	25
3.3.4	Cyber Security Architecture	25
3.3.5	Identity and Access Management.....	26
3.3.6	Application Security	27
3.3.7	Change Management.....	27
3.3.8	Infrastructure Security	28
3.3.9	Cryptography.....	29
3.3.10	Bring Your Own Device (BYOD)	30
3.3.11	Secure Disposal of Information Assets	30
3.3.12	Payment Systems	31
3.3.13	Electronic Banking Services.....	31
3.3.14	Cyber Security Event Management	33
3.3.15	Cyber Security Incident Management	33
3.3.16	Threat Management	34
3.3.17	Vulnerability Management	35
3.4	Third Party Cyber Security	36
3.4.1	Contract and Vendor Management	36
3.4.2	Outsourcing.....	37
3.4.3	Cloud Computing	37
Appendices		39
Appendix A - Overview previous issued SAMA circulars		40
Appendix B - How to request an Update to the Framework		41
Appendix C – Framework Update request form.....		42
Appendix D - How to request a Waiver from the Framework.....		43
Appendix E – Framework Waiver request form		44
Appendix F - Glossary.....		45

1 Introduction

1.1 Introduction to the Framework

The current digital society has high expectations of flawless customer experience, continuous availability of services and effective protection of sensitive data. Information assets and online services are now strategically important to all public and private organizations, as well as to broader society. These services are vital to the creation of a vibrant digital economy. They are also becoming systemically important to the economy and to broader national security. All of which underlines the need to safeguard sensitive data and transactions, and thereby ensure confidence in the overall Saudi Financial Sector.

The stakes are high when it comes to the confidentiality, integrity and availability of information assets, and applying new online services and new developments (e.g. Fintech, block chain); while improving resilience against cyber threats. Not only is the dependency on these services growing, but the threat landscape is rapidly changing. The Financial Sector recognizes the rate at which the cyber threats and risks are evolving, as well as the changing technology and business landscape.

SAMA established a Cyber Security Framework (“the Framework”) to enable Financial Institutions regulated by SAMA (“the Member Organizations”) to effectively identify and address risks related to cyber security. To maintain the protection of information assets and online services, the Member Organizations must adopt the Framework.

The objective of the Framework is as follows:

1. To create a common approach for addressing cyber security within the Member Organizations.
2. To achieve an appropriate maturity level of cyber security controls within the Member Organizations.
3. To ensure cyber security risks are properly managed throughout the Member Organizations.

The Framework will be used to periodically assess the maturity level and evaluate the effectiveness of the cyber security controls at Member Organizations, and to compare these with other Member Organizations.

The Framework is based on the SAMA requirements and industry cyber security standards, such as NIST, ISF, ISO, BASEL and PCI.

The Framework supersedes all previous issued SAMA circulars with regard to cyber security. Please refer to ‘Appendix A – Overview previous issued SAMA circulars’ for more details.

1.2 Definition of Cyber Security

Cyber security is defined as the collection of tools, policies, security concepts, security safeguards, guidelines, risk management approaches, actions, training, best practices, assurance, and technologies that can be used to protect the member organization's information assets against internal and external threats.

The general security objectives comprise the following:

- *Confidentiality* – Information assets are accessible only to those authorized to have access (i.e., protected from unauthorized disclosure or (un)intended leakage of sensitive data).

- *Integrity* – Information assets are accurate, complete and processed correctly (i.e., protected from unauthorized modification, *which may include authenticity and non-repudiation*).
- *Availability* – Information assets are resilient and accessible when required (i.e., protected from unauthorized disruption).

1.3 Scope

The Framework defines principles and objectives for initiating, implementing, maintaining, monitoring and improving cyber security controls in Member Organizations.

The Framework provides cyber security controls which are applicable to the information assets of the Member Organization, including:

- Electronic information.
- Physical information (hardcopy).
- Applications, software, electronic services and databases.
- Computers and electronic machines (e.g., ATM).
- Information storage devices (e.g., hard disk, USB stick).
- Premises, equipment and communication networks (technical infrastructure).

The Framework provides direction for cyber security requirements for Member Organizations and its subsidiaries, staff, third parties and customers.

For business continuity related requirements please refer to the SAMA Business Continuity Minimum Requirements.

The Framework has an interrelationship with other corporate policies for related areas, such as physical security and fraud management. This framework does not address the non-cyber security requirements for those areas.

1.4 Applicability

The Framework is applicable to all Member Organizations regulated by SAMA, which include the following:

- All Banks operating in Saudi Arabia;
- All Insurance and/or Reinsurance Companies operating in Saudi Arabia;
- All Financing Companies operating in Saudi Arabia;
- All Credit Bureaus operating In Saudi Arabia;
- The Financial Market Infrastructure

All domains are applicable for the banking sector. However, for other financial institutions the following exceptions apply:

- Sub-domain (3.1.2) the alignment with cyber security strategy of banking sector is mandatory when applicable.
- Exclude sub-domain (3.2.3). However, if the organization store, process or transmit cardholder data or deal with SWIFT services, then PCI standard and/or SWIFT Customer Security Controls Framework should be implemented.
- Exclude sub-domain (3.3.12).

- Exclude sub-domain (3.3.13). However, if the organization provides online services for customers, a Multi Factor Authentication capability should be implemented.

1.5 Responsibilities

The framework is mandated by SAMA. SAMA is the owner and is responsible for periodically updating the Framework.

The Member Organizations are responsible for adopting and implementing the Framework.

1.6 Interpretation

SAMA, as the owner of the Framework, is solely responsible for providing interpretations of the principles, objectives and control considerations, if required.

1.7 Target Audience

The Framework is intended for senior and executive management, business owners, owners of information assets, CISOs and those who are responsible for and involved in defining, implementing and reviewing cyber security controls within the Member Organizations.

1.8 Review, Updates and Maintenance

The Framework will be reviewed and maintained by SAMA.

SAMA will review the Framework periodically to determine the Framework's effectiveness, including the effectiveness of the Framework to address emerging cyber security threats and risks. If applicable, SAMA will update the Framework based on the outcome of the review.

If a Member Organization considers that an update to the Framework is required, the Member Organization should formally submit the requested update to SAMA. SAMA will review the requested update, and when approved, the Framework will be adjusted.

The Member Organization will remain responsible to be compliant with the Framework pending the requested update.

Please refer to 'Appendix B – How to request an Update to the Framework' for the process of requesting an update to the Framework.

Version control will be implemented for maintaining the Framework. Whenever any changes are made, the preceding version shall be retired and the new version shall be published and communicated to all Member Organizations. For the convenience of the Member Organizations, changes to the Framework shall be clearly indicated.

1.9 Reading Guide

The Framework is structured as follows. Chapter 2 elaborates on the structure of the Framework, and provides instructions on how to apply the Framework. Chapter 3 presents the actual Framework, including the cyber security domains and subdomains, principles, objectives and control considerations.

2 Framework Structure and Features

2.1 Structure

The Framework is structured around four main domains, namely:

- Cyber Security Leadership and Governance.
- Cyber Security Risk Management and Compliance.
- Cyber Security Operations and Technology.
- Third Party Cyber Security.

For each domain, several subdomains are defined. A subdomain focusses on a specific cyber security topic. Per subdomain, the Framework states a principle, objective and control considerations.

- A **principle** summarizes the main set of required cyber security controls related to the subdomain.
- The **objective** describes the purpose of the principle and what the set of required cyber security controls are expected to achieve.
- The **control considerations** reflects the mandated cyber security controls that should be considered.

Control considerations have been uniquely numbered throughout the Framework. Where applicable, a control consideration can consist of up to 4 levels.

The control considerations are numbered according to the following numbering system:

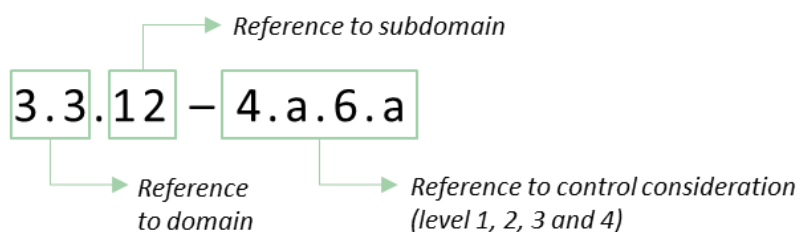


Figure 1 – Control consideration numbering system

The figure below illustrates the overall structure of the Framework and indicates the cyber security domains and subdomains, including a reference to the applicable section of the Framework.

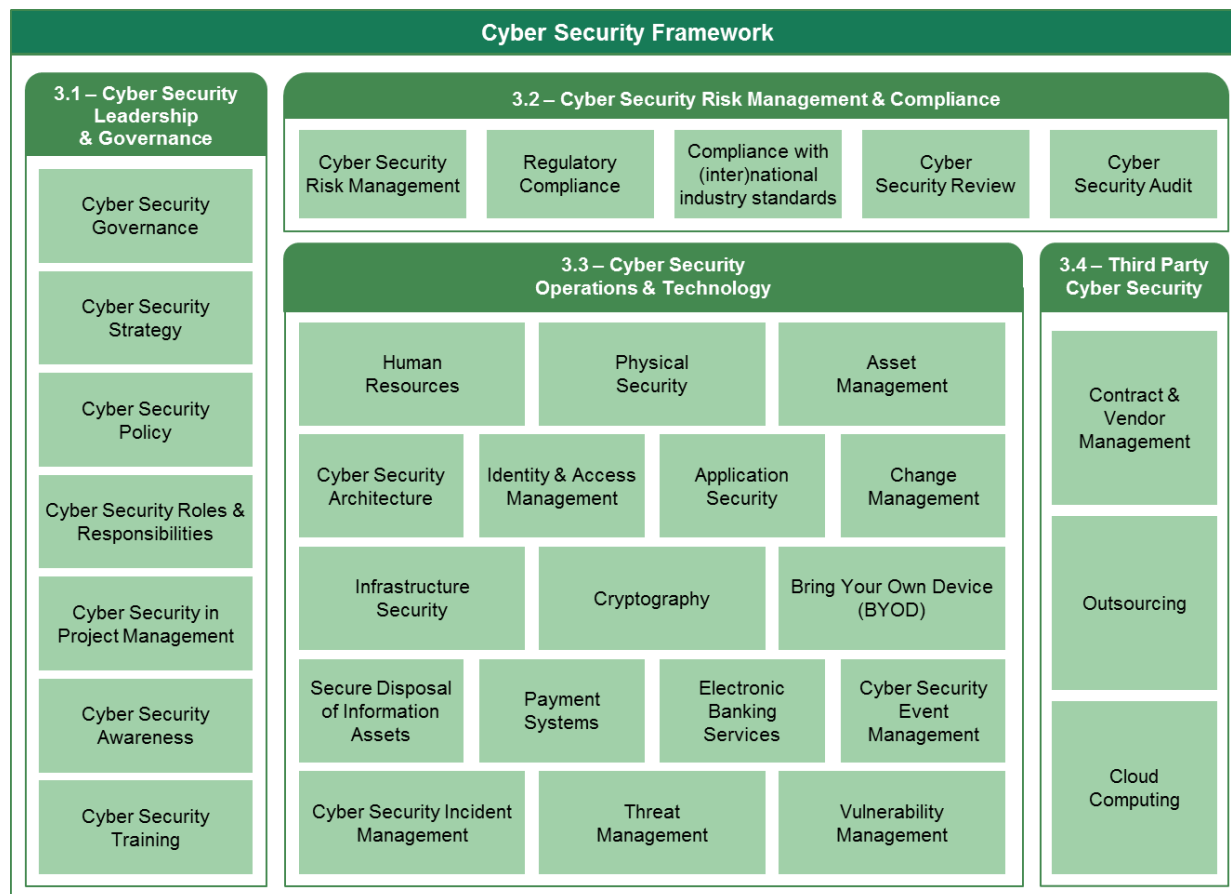


Figure 2 - Cyber Security Framework

2.2 Principle-based

The Framework is principle based, also referred to as risk based. This means that it prescribes key cyber security principles and objectives to be embedded and achieved by the Member Organization. The list of mandated control considerations provides additional direction and should be considered by the Member Organization in achieving the objectives. When a certain control consideration cannot be tailored or implemented, the Member Organization should consider applying compensating controls, pursuing an internal risk acceptance and requesting a formal waiver from SAMA.

Please refer to Appendix D for details for the – How to request a Waiver from the Framework – process.

2.3 Self-Assessment, Review and Audit

The implementation of the Framework at the Member Organization will be subject to a periodic self-assessment. The self-assessment will be performed by the Member Organization based on a questionnaire. The self-assessments will be reviewed and audited by SAMA to determine the level of compliance with the Framework and the cyber security maturity level of the Member Organization.

Please refer to '2.4 Cyber Security Maturity Model' for more details about the cyber security maturity model.

2.4 Cyber Security Maturity Model

The cyber security maturity level will be measured with the help of a predefined cyber security maturity model. The cyber security maturity model distinguishes 6 maturity levels (0, 1, 2, 3, 4 and 5), which are summarized in the table below. In order to achieve levels 3, 4 or 5, a Member Organization must first meet all criteria of the preceding maturity levels.

Maturity Level	Definition and Criteria	Explanation
0 Non-existent	- No documentation. - There is no awareness or attention for certain cyber security control.	Cyber security controls are not in place. There may be no awareness of the particular risk area or no current plans to implement such cyber security controls.
1 Ad-hoc	- Cyber security controls is not or partially defined. - Cyber security controls are performed in an inconsistent way. - Cyber security controls are not fully defined.	- Cyber security control design and execution varies by department or owner. - Cyber security control design may only partially mitigate the identified risk and execution may be inconsistent.
2 Repeatable but informal	The execution of the cyber security control is based on an informal and unwritten, though standardized, practice.	- Repeatable cyber security controls are in place. However, the control objectives and design are not formally defined or approved. - There is limited consideration for a structured review or testing of a control.
3 Structured and formalized	- Cyber security controls are defined, approved and implemented in a structured and formalized way. - The implementation of cyber security controls can be demonstrated.	- Cyber security policies, standards and procedures are established. - Compliance with cyber security documentation i.e., policies, standards and procedures is monitored, preferably using a governance, risk and compliance tool (GRC). - key performance indicators are defined, monitored and reported to evaluate the implementation.
4 Managed and measurable	- The effectiveness of the cyber security controls are periodically assessed and improved when necessary. - This periodic measurement, evaluations and opportunities for improvement are documented.	- Effectiveness of cyber security controls are measured and periodically evaluated. - key risk indicators and trend reporting are used to determine the effectiveness of the cyber security controls. - Results of measurement and evaluation are used to identify opportunities for improvement of the cyber security controls.
5 Adaptive	Cyber security controls are subject to a continuous improvement plan.	- The enterprise-wide cyber security program focuses on continuous compliance, effectiveness and improvement of the cyber security controls. - Cyber security controls are integrated with enterprise risk management framework and practices. - Performance of cyber security controls are evaluated using peer and sector data.

Table 1 - Cyber Security Maturity Model

The objective of the Framework is to create an effective approach for addressing cyber security and managing cyber security risks within the Financial Sector. To achieve an appropriate cyber security maturity level, the Member Organizations should at least operate at maturity level 3 or higher as explained below.

2.4.1 Maturity Level 3

To achieve level 3 maturity, a Member Organization should define, approve and implement cyber security controls. In addition, it should monitor compliance with the cyber security documentation .

The cyber security documentation should clearly indicate “why”, “what” and “how” cyber security controls should be implemented. The cyber security documentation consists of cyber security policies, cyber security standards and cyber security procedures.

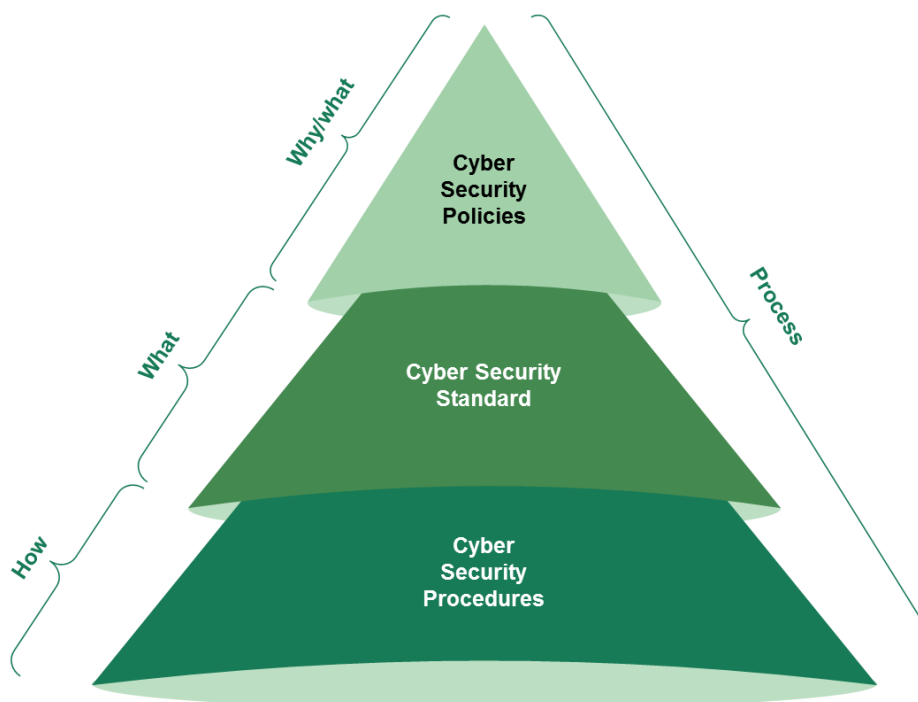


Figure 3 - Cyber Security Documentation Pyramid

The cyber security policy should be endorsed and mandated by the board of the Member Organization and stating “why” cyber security is important to the Member Organization. The policy should highlight which information assets must be protected and “what” cyber security principles and objectives should be established.

Based on the cyber security policy, cyber security standards must be developed. These standards define “what” cyber security controls must be implemented, such as security and system parameters, segregation of duties, password rules, monitoring events and back-up and recovery rules. The standards support and reinforce the cyber security policy and are to be considered as cyber security baselines.

The step-by-step tasks and activities that should be performed by staff, third parties or customers of the Member Organization are detailed in the cyber security procedures. These procedures prescribe “how” the cyber security controls, tasks and activities have to be executed in the operating environment and support the safeguarding of the information assets of the Member Organization according to the cyber security policy and standards.

The process in the context of this framework is defined as a structured set of activities designed to accomplish the specified objective. A process may include policies, standards, guidelines, procedures, activities and work instructions, as well as any of the roles, responsibilities, tools and management controls required to reliably deliver the output.

The actual progress of the implementation, performance and compliance of the cyber security controls should be periodically monitored and evaluated using key performance indicators (KPIs).

2.4.2 Maturity Level 4

To achieve maturity level 4, the Member Organization should periodically measure and evaluate the effectiveness of implemented cyber security controls. In order to measure and evaluate whether the cyber

security controls are effective, key risk indicators (KRIs) should be defined. A KRI indicates the norm for effectiveness measurement and should define thresholds to determine whether the actual result of measurement is below, on, or above the targeted norm. KRIs are used for trend reporting and identification of potential improvements.

2.4.3 Maturity Level 5

Maturity level 5 focuses on the continuous improvement of cyber security controls. Continuous improvement is achieved through continuously analyzing the goals and achievements of cyber security and identifying structural improvements. Cyber security controls should be integrated with enterprise risk management practices and supported with automated real-time monitoring. Business process owners should be accountable for monitoring the compliance of the cyber security controls, measuring the effectiveness of the cyber security controls and incorporating the cyber security controls within the enterprise risk management framework . Additionally, the performance of cyber security controls should be evaluated using peer and sector data.

3 Control domains

3.1 Cyber Security Leadership and Governance

The ultimate responsibility for cyber security rests with the board of the Member Organization. The board of the Member Organization can delegate its cyber security responsibilities to a cyber security committee (or a senior manager from a control function). The cyber security committee could be responsible for defining the cyber security governance and setting the Member Organization's cyber security strategy. The cyber security committee can also be responsible for defining a cyber security policy and ensuring the operational effectiveness of this cyber security policy.

To develop and maintain the cyber security policy and to execute the cyber security activities across the Member Organization, an independent cyber security function should be established.

3.1.1 Cyber Security Governance

Principle

A cyber security governance structure should be defined and implemented, and should be endorsed by the board.

Objective

To direct and control the overall approach to cyber security within the Member Organization.

Control considerations

1. A cyber security committee should be established and be mandated by the board.
2. The cyber security committee should be headed by an independent senior manager from a control function.
3. The following positions should be represented in the cyber security committee:
 - a. senior managers from all relevant departments (e.g., COO, CIO, compliance officer, heads of relevant business departments);
 - b. Chief information security officer (CISO);
 - c. Internal audit may attend as an "observer."
4. A cyber security committee charter should be developed, approved and reflect:
 - a. committee objectives;
 - b. roles and responsibilities;
 - c. minimum number of meeting participants;
 - d. meeting frequency (minimum on quarterly basis).
5. A cyber security function should be established.
6. The cyber security function should be independent from the information technology function. To avoid any conflict of interest, the cyber security function and information technology function should have separate reporting lines, budgets and staff evaluations.
7. The cyber security function should report directly to the CEO/managing director of the Member Organization or general manager of a control function.
8. A full-time senior manager for the cyber security function, referred to as CISO, should be appointed at senior management level.
9. The Member Organization should :
 - a. ensure the CISO has a Saudi nationality;
 - b. ensure the CISO is sufficiently qualified;

3.4 Third Party Cyber Security

When Member Organizations do rely on, or have to deal with third party services, it is key to ensure the same level of cyber security protection is implemented at the third party, as within the Member Organization.

This paragraph describes how the cyber security requirements between the Member Organization and Third Parties should be organized, implemented and monitored. Third Parties in this Framework are defined as, information services providers, outsourcing providers, cloud computing providers, vendors, suppliers, governmental agencies, etc.

3.4.1 Contract and Vendor Management

Principle

The Member Organization should define, approve, implement and monitor the required cyber security controls within the contract and vendor management processes.

Objective

To ensure that the Member Organization's approved cyber security requirements are appropriately addressed before signing the contract, and the compliance with the cyber security requirements is being monitored and evaluated during the contract life-cycle.

Control Considerations

1. The cyber security requirements should be defined, approved, implemented and communicated within the contract and vendor management processes.
2. The compliance with contract and vendor management process should be monitored.
3. The effectiveness of the cyber security controls within the contract and vendor management process should be measured and periodically evaluated.
4. These contract and vendor management processes should cover:
 - a. whether the involvement of the cyber security function is actively required (e.g., in case of due diligence);
 - b. the baseline cyber security requirements which should be applied in all cases;
 - c. the right to periodically perform cyber security reviews and audits.
5. The contract management process should cover requirements for:
 - a. executing a cyber security risk assessment as part of the procurement process;
 - b. defining the specific cyber security requirements as part of the tender process;
 - c. evaluating the replies of potential vendors on the defined cyber security requirements;
 - d. testing of the agreed cyber security requirements (risk-based);
 - e. defining the communication or escalation process in case of cyber security incidents;
 - f. ensuring cyber security requirements are defined for exiting, terminating or renewing the contract (including escrow agreements if applicable);
 - g. defining a mutual confidentiality agreement.
6. The vendor management process (i.e., service level management) should cover requirements for:
 - a. periodic reporting, reviewing and evaluating the contractually agreed cyber security requirements (in SLAs).

3.4.2 Outsourcing

Principle

The Member Organization should define, implement and monitor the required cyber security controls within outsourcing policy and outsourcing process. The effectiveness of the defined cyber security controls should periodically be measured and evaluated.

Objective

To ensure that the Member Organization's cyber security requirements are appropriately addressed before, during and while exiting outsourcing contracts.

Control Considerations

1. The cyber security requirements within the outsourcing policy and process should be defined, approved, implemented and communicated within Member Organization.
2. The cyber security requirements regarding the outsourcing policy and process should be measured and periodically evaluated.
3. The outsourcing process should include:
 - a. the approval from SAMA prior to material outsourcing;
 - b. the involvement of the cyber security function;
 - c. compliance with the SAMA circular on outsourcing.

3.4.3 Cloud Computing

Principle

The Member Organization should define, implement and monitor the required cyber security controls within the cloud computing policy and process for hybrid and public cloud services. The effectiveness of the defined cyber security controls should periodically be measured and evaluated.

Please note that this requirement is not applicable to private cloud services (= internal cloud).

Objective

To ensure that all functions and staff within the Member Organization are aware of the agreed direction and position on hybrid and public cloud services, the required process to apply for hybrid and public cloud services, the risk appetite on hybrid and public cloud services and the specific cyber security requirements for hybrid and public cloud services.

Control Considerations

1. The cyber security controls within the cloud computing policy for hybrid and public cloud services should be defined, approved and implemented and communicated within Member Organization.
2. The compliance with the cloud computing policy should be monitored.
3. The cyber security controls regarding the cloud computing policy and process for hybrid and public cloud services should be periodically measured and evaluated.
4. The cloud computing policy for hybrid and public cloud services should address requirements for:
 - a. the process for adopting cloud services, including that:
 1. a cyber security risk assessment and due diligence on the cloud service provider and its cloud services should be performed;

2. the Member Organization should obtain SAMA approval prior to using cloud services or signing the contract with the cloud provider;
3. a contract should be in place, including the cyber security requirements, before using cloud services;
- b. data location, including that:
 1. in principle only cloud services should be used that are located in Saudi Arabia, or when cloud services are to be used outside Saudi Arabia that the Member Organization should obtain explicit approval from SAMA;
- c. data use limitations, including that:
 1. the cloud service provider should not use the Member Organization's data for secondary purposes;
- d. security, including that:
 1. the cloud service provider should implement and monitor the cyber security controls as determined in the risk assessment for protecting the confidentiality, integrity and availability of the Member Organization's data;
- e. data segregation, including that:
 1. the Member Organization's data is logically segregated from other data held by the cloud service provider, including that the cloud service provider should be able to identify the Member Organization's data and at all times should be able to distinguish it from other data.
- f. business continuity, including that:
 1. business continuity requirements are met in accordance with the Member Organization's business continuity policy;
- g. audit, review and monitoring, including that:
 1. the Member Organization has the right to perform a cyber security review at the cloud service provider;
 2. the Member Organization has the right to perform a cyber security audit at the cloud service provider;
 3. the Member Organization has the right to perform a cyber security examination at the cloud service provider;
- h. exit, including that:
 1. the Member Organization has termination rights;
 2. the cloud service provider has to return the Member Organization's data on termination;
 3. the cloud service provider has to irreversibly delete the Member Organization's data on termination.